

W20D4 - Security Operations

Franco il salumiere - SecOps

Network Design

Danilo 'danix' Macrì - mia.mail@mio.sito

Scan started on 22/11/2025 - duration (days): 1

Contents

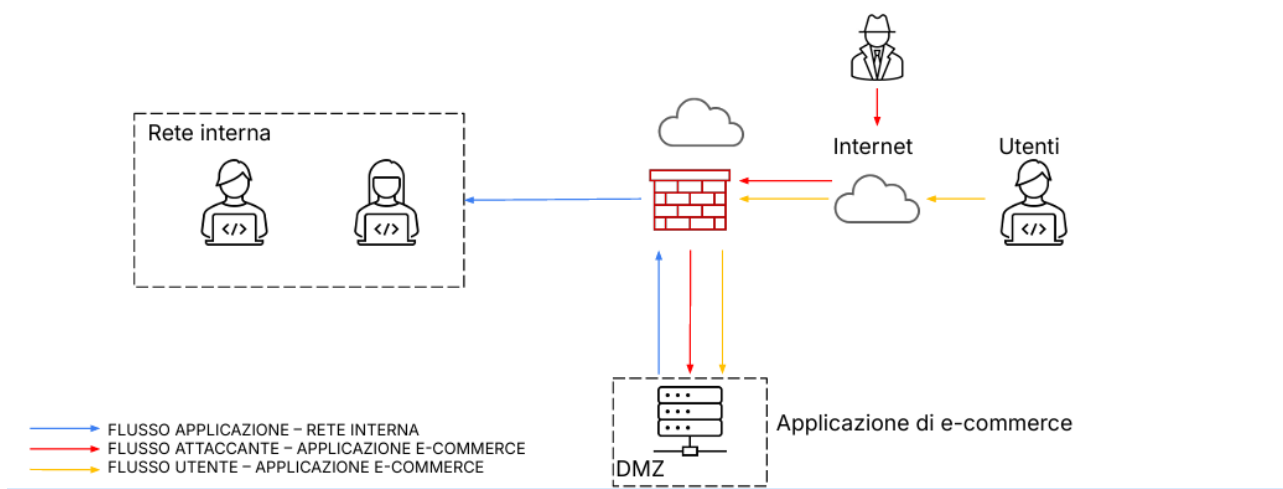
Sommario	1
Traccia	1
Azioni Preventive	1
Impatto sul Business	2
Response	2
Soluzione completa	2
In conclusione	3

Sommario

Nell'esercizio di oggi andremo a prendere in esame un'infrastruttura di rete allo scopo di migliorarla risolvendo alcune problematiche e mitigando il rischio di attacchi DDoS alla webapp offerta.

Traccia

Con riferimento alla figura seguente, rispondere ai quesiti:



1. **Azioni preventive:** quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato? Modificate la figura in modo da evidenziare le implementazioni
2. **Impatto sul business:** l'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica
3. **Response:** l'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta.

Soluzione completa: unire i disegni dell'**azione preventiva** e della **response** (unire soluzione 1 e 3)

Modifica «più aggressiva» dell'infrastruttura (se necessario/facoltativo magari integrando la soluzione al punto 2)

Azioni Preventive

Per difendere la nostra webapp da attacchi di tipo SQLi o XSS la prima cosa da fare è un'accurata review del codice in modo da rimuovere eventuali input da parte dell'utente che non siano sanificati prima di essere parsati dal nostro codice.

Un'ulteriore livello di sicurezza possiamo ottenerlo implementando un Web Application Firewall (WAF) che vada a porsi tra il traffico internet e la nostra webapp, in modo da bloccare eventuali input malevoli prima che possano essere inseriti nei campi della nostra webapp.

Impatto sul Business

Durante un attacco di tipo DDoS, la nostra piattaforma e-commerce viene resa irraggiungibile per 10 minuti e questo ci costa in media 1500€ al minuto, quindi perdiamo circa 15000€ a causa di questo attacco.

Per proteggere la nostra applicazione da questo genere di attacchi si possono intraprendere diverse strade, il nostro WAF può essere configurato in modo da non permettere troppe richieste dallo stesso client contemporaneamente (throttling), in base alle risorse del nostro server e alla media di visite che riceviamo, possiamo gestire la quantità di risorse che il nostro sistema sarà in grado di utilizzare.

Una strada diversa potrebbe essere quella di implementare un sistema di load balancing, nel quale andiamo a redirigere il traffico verso un altro server nel momento in cui le risorse del nostro server principale vadano esaurendosi. Idealmente avremo più server ridondanti, situati in aree geografiche differenti, in modo da offrire i contenuti ai nostri clienti dalla rotta più vicina ad essi e garantendoci così risorse sufficienti anche in caso di picchi di traffico.

Response

Nell'ipotesi che attraverso la nostra webapp una macchina venga compromessa da un malware, è essenziale isolare la macchina compromessa in una lan separata dal resto dell'infrastruttura, possibilmente senza privarla dell'accesso a internet in modo da poter eseguire le opportune indagini e tentare di risalire al soggetto attaccante.

Una volta messa in sicurezza si potrà sostituire la macchina infetta con una nuova macchina su cui verranno caricati i backup dei dati e questa verrà integrata nella lan in produzione.

Soluzione completa

Nello schema allegato al presente report, abbiamo integrato tutte le soluzioni proposte con alcune modifiche alla struttura della nostra rete, in modo da offrire una maggiore protezione contro gli attacchi.

WAF, Load Balancer Al nostro Firewall è stato affiancato un WAF per gestire le richieste verso la nostra piattaforma di e-commerce. Quest'ultima viene sviluppata in-house e messa in produzione su una prima serie di macchine che vengono poi clonate su altre 2 location geodistribuite in modo da aumentare le risorse a disposizione e rispondere meglio ai picchi di traffico.

Questa soluzione si basa su un load balancer che si occupa di distribuire il traffico tra le varie location.

Subnet segregation La LAN dove avviene lo sviluppo della web app e il monitoraggio dell'infrastruttura è isolata dalle macchine in produzione.

Quarantine Subnet Abbiamo implementato una sottorete di quarantena in cui abbiamo isolato una macchina infetta da un malware, abbiamo lasciato attiva la connessione in modo da poter effettuare un'analisi del malware e risalire al soggetto attaccante.

SIEM / SOAR Abbiamo implementato dei sistemi di monitoraggio passivi (SIEM) e attivi (SOAR) collegati a tutta la rete in modo da tenere sotto controllo tutti gli eventi prodotti nell'infrastruttura e reagendo in maniera tempestiva (e automatica dove possibile) ai potenziali attacchi.

In conclusione

Con le modifiche discusse in questo documento abbiamo migliorato molto la postura di sicurezza della nostra infrastruttura, rendendo la nostra piattaforma più resiliente agli attacchi e migliorando la user experience dei nostri acquirenti allo stesso tempo.

Si consiglia di implementare delle routine di Penetration Testing per migliorare ulteriormente la capacità di prevenire eventuali attacchi.

In allegato al presente documento lo schema dell'infrastruttura di rete aggiornata -> [network infrastructure.pdf](#)

Con questo si conclude il nostro esercizio di oggi.

Alla prossima.

